



Principes Fondamentaux d'IAM

IAM est un service mondial qui vous permet de gérer les accès aux services et ressources AWS de manière sécurisée.

Composant IAM

Utilisateur (User)

Représente une personne physique (un administrateur, un développeur, etc.) qui se connecte à AWS. Ne jamais utiliser l'utilisateur Root (Racine) pour les tâches quotidiennes.

Groupe (Group)

Une collection d'utilisateurs IAM. Les autorisations sont attachées au groupe pour faciliter la gestion (ex: Administrateurs, Développeurs S3).

Politique (Policy)

Un document JSON qui définit les autorisations : ce qui est autorisé ou refusé pour une ressource spécifique.

Rôle (Role)

Une identité que vous pouvez créer pour attribuer des autorisations temporaires à des entités :

1. Des services AWS (ex: permettre à une instance EC2 d'accéder à S3).
2. Des utilisateurs extérieurs au compte.

Démarrage Sécurisé

Les 3 Actions Cruciales à Faire Immédiatement

Pour bien démarrer avec IAM et sécuriser votre compte, faites ces étapes dans cet ordre :



1. Sécuriser l'Utilisateur Root (Racine)

L'utilisateur Root a des droits illimités sur votre compte et ne doit être utilisé que pour des tâches très rares (comme modifier les paramètres de facturation ou fermer le compte).

Action

Activez l'authentification multi-facteur (MFA) sur l'utilisateur Root immédiatement. Utilisez un périphérique physique ou une application (comme Google Authenticator ou Authy).

Sécurité

Stockez les identifiants Root et le périphérique MFA dans un endroit très sûr.

2. Créer un Utilisateur Administrateur Spécifique

Vous avez besoin d'un utilisateur pour les tâches d'administration quotidiennes.

01

Action

Créez un nouvel utilisateur IAM dédié.

02

Attacher une Politique

Attachez la politique gérée par AWS nommée AdministratorAccess à cet utilisateur.

03

Connexion

Cet utilisateur utilisera un nom d'utilisateur et un mot de passe (et la MFA !) pour se connecter à la console.

3. Activer le MFA pour l'Utilisateur Administrateur

C'est une deuxième ligne de défense pour votre accès quotidien.



Action : Activez l'authentification multi-facteur (MFA) pour votre nouvel utilisateur administrateur.

Utilisateur Root

L'utilisateur root (racine) est l'identité la plus puissante et la plus critique de votre compte AWS. 🏰 Il est créé automatiquement lorsque vous ouvrez votre compte AWS.

Rôle et Pouvoirs de l'Utilisateur Root

L'utilisateur root a un accès illimité et universel à tous les services et ressources de votre compte AWS, y compris la facturation et les paramètres de sécurité les plus sensibles. C'est l'équivalent du super-administrateur.

Caractéristique	Détail
Accès Maximal	Peut effectuer des tâches que seul le root peut faire (ex: changer le plan de support, fermer le compte).
Non-Utilisation	Il ne doit jamais être utilisé pour les tâches quotidiennes. Il est recommandé de le traiter comme un "coffre-fort" numérique.
Identifiants	Il se connecte en utilisant l'adresse e-mail et le mot de passe associés au compte.

Meilleures Pratiques de Sécurité

La sécurité de l'utilisateur root est la priorité absolue d'IAM. Voici les étapes à suivre immédiatement après avoir créé votre compte :

1

Activer l'Authentification Multi-Facteur (MFA)

C'est l'étape la plus importante.

- **Action :** Activez l'authentification multi-facteur (MFA) pour l'utilisateur root (Racine).
- **Recommandation :** Utilisez un appareil physique ou une application dédiée (comme Google Authenticator ou Authy) pour générer le code.

2

Utilisation Limitée

Utilisez l'utilisateur root uniquement pour les tâches administratives suivantes :

- Changer l'adresse e-mail associée à votre compte.
- Modifier les paramètres de facturation et de paiement.
- Changer le type de plan de support AWS.
- Fermer le compte AWS.

3

Stockage Sécurisé

- **Mot de passe :** Créez un mot de passe fort et unique que vous stockez dans un gestionnaire de mots de passe sécurisé.
- **MFA :** Assurez-vous que l'appareil MFA est stocké en toute sécurité.

En résumé : connectez-vous avec l'utilisateur root une seule fois pour créer un utilisateur IAM administrateur dédié et activer la MFA sur le compte root. Ensuite, déconnectez-vous et n'utilisez plus le compte root. Toutes les opérations courantes doivent être effectuées avec des utilisateurs IAM non-root.

Utilisateurs IAM

Un utilisateur IAM (Identity and Access Management) est une identité que vous créez dans votre compte AWS pour représenter une personne physique (un employé, un administrateur, un développeur) ou un service d'application qui a besoin d'accéder aux ressources AWS. 🏠

Il se distingue de l'utilisateur root (racine) par les principes suivants :

Caractéristiques Clés

Accès Spécifique (Least Privilege)

Contrairement à l'utilisateur root, un utilisateur IAM n'a aucune permission par défaut. Il doit se voir attribuer explicitement des autorisations via des politiques (policies) pour interagir avec les services AWS (comme démarrer une instance EC2 ou lire un fichier S3).

Connexion Sécurisée

L'utilisateur IAM se connecte via une console AWS spécifique à votre compte ou par programmation en utilisant des clés d'accès (Access Keys).

Séparation des Rôles

Il est strictement recommandé d'utiliser des utilisateurs IAM pour toutes les tâches quotidiennes, y compris l'administration, et de ne jamais utiliser l'utilisateur root.

Gestion des Utilisateurs IAM

La gestion des utilisateurs est généralement organisée de la manière suivante :



Création

Vous créez l'utilisateur dans la console IAM, en définissant un nom et un mot de passe initial (ou en générant des clés d'accès).



Groupes

Le plus souvent, un utilisateur est placé dans un Groupe IAM (ex: Développeurs Backend, Analystes Data). Les autorisations sont alors attachées au groupe, ce qui simplifie la gestion des accès pour plusieurs personnes ayant les mêmes responsabilités.



Politiques

Les politiques d'autorisation sont attachées soit directement à l'utilisateur (rare), soit au groupe auquel il appartient (préférable). Ces politiques déterminent quelles actions (Action), sur quelles ressources (Resource), sont autorisées ou refusées (Effect).

Sécurité des Utilisateurs IAM

La sécurité est primordiale pour les utilisateurs IAM :

- **MFA Obligatoire** : Vous devez toujours exiger et activer l'Authentification Multi-Facteur (MFA) pour tous les utilisateurs IAM, en particulier les administrateurs.
- **Clés d'Accès** : Si un utilisateur a besoin d'accéder à AWS de manière programmatique (via CLI, SDK ou une application), il utilise des clés d'accès (un ID de clé et une clé secrète). Celles-ci doivent être traitées comme des mots de passe et ne jamais être codées en dur.
- **Rotation des Clés** : Il est conseillé de procéder régulièrement à la rotation des clés d'accès pour minimiser le risque de compromission.

Groupe IAM

Un Groupe IAM (Identity and Access Management) est simplement une collection d'utilisateurs IAM au sein de votre compte AWS. 👤 Le but principal d'un groupe est de simplifier la gestion des autorisations.

Rôle et Fonctionnement

Au lieu d'attacher des politiques d'autorisation individuelles à chaque utilisateur, vous attachez des politiques au groupe. Tous les utilisateurs ajoutés à ce groupe héritent automatiquement des autorisations définies par ces politiques.

Exemples de Groupes:

Nom du Groupe	Rôle Typique	Politiques Associées (Exemples)
Administrateurs	Gestion complète de toutes les ressources.	AdministratorAccess
Développeurs S3	Lecture/écriture de code et de données sur les buckets de développement.	AmazonS3FullAccess, AmazonEC2ReadOnlyAccess
Auditeurs	Capacité de lire et de lister les ressources, mais sans modifier quoi que ce soit.	ReadOnlyAccess

Principes Clés

1. **Héritage Automatique** : Si vous ajoutez un utilisateur au groupe "Développeurs S3", cet utilisateur peut immédiatement lire et écrire sur S3. Si vous le retirez du groupe, il perd ces permissions.
2. **Un Utilisateur, Plusieurs Groupes** : Un utilisateur IAM peut appartenir à plusieurs groupes. L'utilisateur disposera alors de l'ensemble des autorisations de tous les groupes auxquels il appartient (les permissions s'additionnent).
3. **Gestion Simplifiée** : Si vous devez révoquer ou accorder une nouvelle permission à 50 développeurs, il suffit de modifier la politique attachée à leur seul groupe, au lieu de modifier 50 utilisateurs individuellement.

Important : Les Groupes ne Peuvent Pas S'Authentifier

Il est crucial de noter qu'un Groupe IAM est uniquement un conteneur logique d'autorisations.

- Il ne possède pas de mot de passe, ni de clé d'accès.
- Il ne peut pas être utilisé pour se connecter ou faire des appels d'API.

Seuls les Utilisateurs IAM et les Rôles IAM peuvent s'authentifier.

Politique IAM

Une politique IAM (Identity and Access Management) est un document qui définit les autorisations pour un utilisateur, un groupe ou un rôle IAM.

📄 C'est le cœur du système de sécurité d'AWS : elle détermine qui peut faire quoi et sur quelles ressources.

Structure d'une Politique

Les politiques IAM sont écrites au format JSON et suivent une structure standard. L'élément central est le tableau de Déclarations (Statement), chacune décrivant une règle d'accès unique.

Élément	Description	Exemple
Effect	L'effet de la déclaration : Allow (Autoriser) ou Deny (Refuser).	"Effect": "Allow"
Action	L'action ou l'opération spécifique que l'identité peut effectuer. Elle est toujours structurée en service:opération.	"Action": "s3:GetObject" (Lire un objet S3)
Resource	Le(s) objet(s) ou ressource(s) spécifique(s) sur le(s)quel(s) l'action est autorisée ou refusée. C'est un ARN (Amazon Resource Name).	"Resource": "arn:aws:s3:::mon-bucket/*"
Principal	(Uniquement dans les politiques de ressources) L'identité (utilisateur, rôle, service) qui est autorisée ou refusée.	N/A (Non utilisé dans les politiques d'identité)

Exemple de Politique JSON

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowS3ReadOnly",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject",
        "s3:ListBucket"
      ],
      "Resource": "arn:aws:s3:::mon-super-bucket-data/*"
    }
  ]
}
```

Cette politique permet de lire des objets (GetObject) et de lister le contenu (ListBucket) uniquement dans le bucket mon-super-bucket-data.

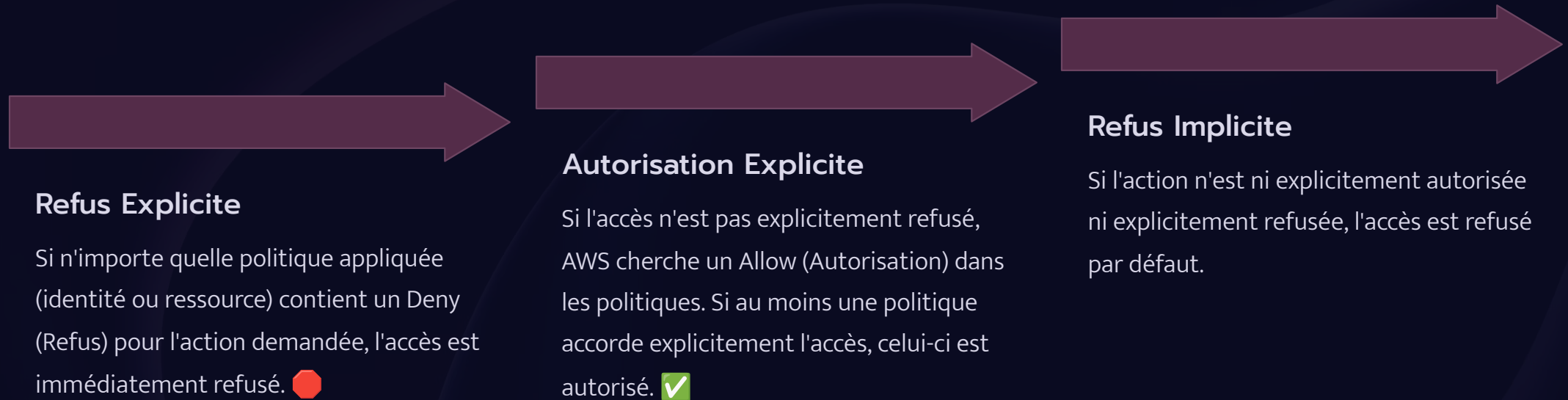
Types de Politiques

AWS utilise différents types de politiques pour différents cas d'usage :

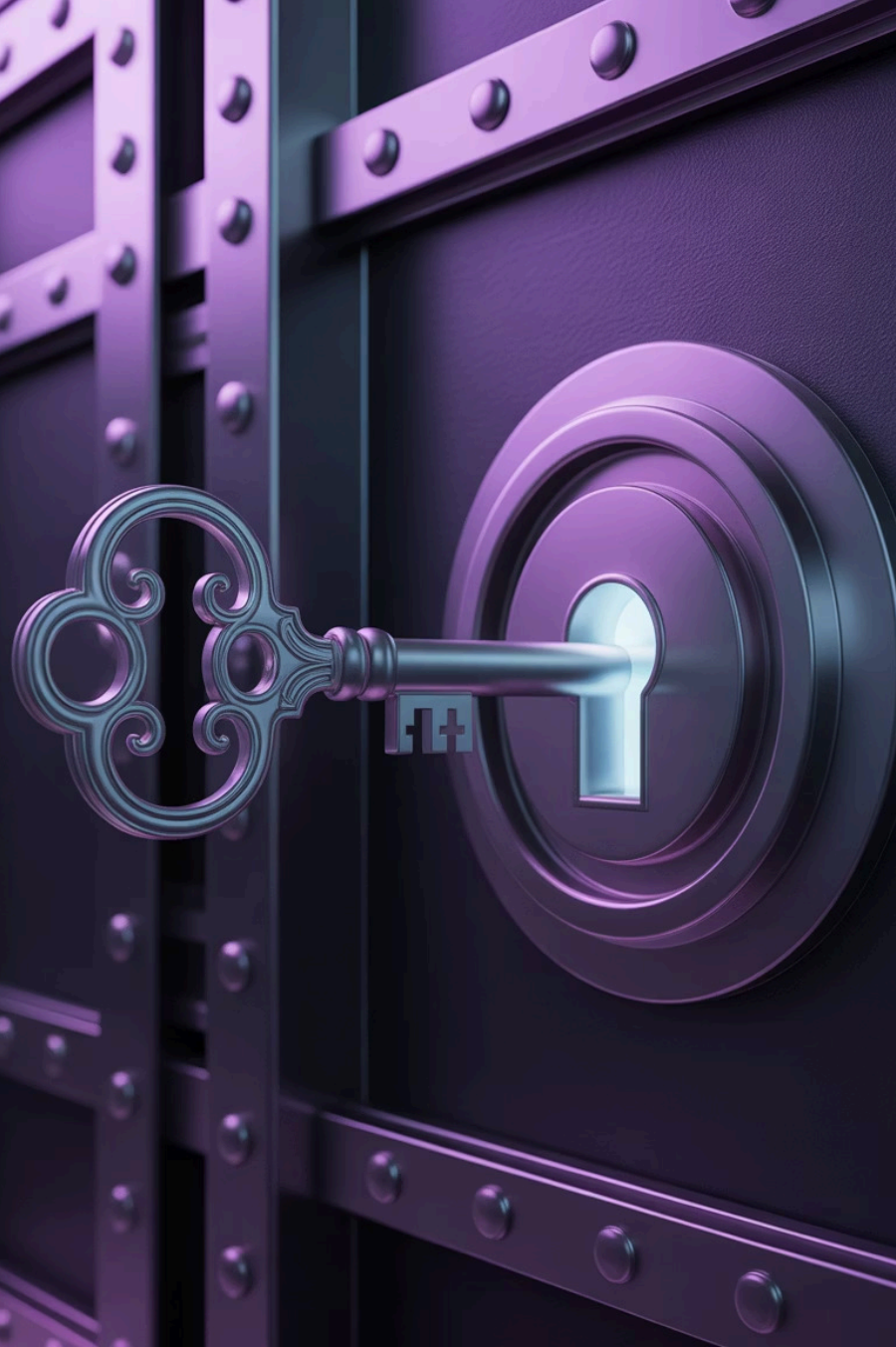
Type de Politique	Où elle est attachée	Fonction
Politique d'Identité (Identity-based)	Utilisateurs, Groupes, Rôles.	Gère les autorisations de l'identité qui la porte. C'est la plus courante.
Politique de Ressource (Resource-based)	À une ressource spécifique (ex: un bucket S3, une clé KMS).	Gère qui, d'une autre identité, peut accéder à cette ressource.
Boundary de Permissions (Permissions Boundary)	Utilisateurs ou Rôles.	Définit le maximum de permissions qu'une identité peut avoir. C'est une limite de sécurité.

Logique d'Évaluation (L'Ordre d'Accès)

Lorsqu'un utilisateur tente d'accéder à une ressource, AWS évalue toutes les politiques applicables dans cet ordre :



Règle d'or : L'accès est refusé par défaut. Le refus explicite l'emporte toujours sur l'autorisation. Vous devez toujours accorder explicitement les permissions. C'est le principe du Moindre Privilège.



Principe du Moindre Privilège (Least Privilege)

La meilleure pratique consiste à toujours accorder uniquement les autorisations nécessaires pour accomplir une tâche spécifique.

Mauvaise Pratique

Donner `s3:*` (accès complet à S3) à un développeur qui n'a besoin que de lire des fichiers dans un seul bucket.

Bonne Pratique

Utiliser des actions spécifiques comme `s3:GetObject` sur l'ARN exact du bucket requis.

En suivant ces étapes, vous établissez une base solide et sécurisée pour votre utilisation future des services AWS.

Rôle IAM

Un Rôle IAM (Identity and Access Management) est une identité IAM qui n'est pas associée de manière permanente à une personne physique (contrairement à un utilisateur). 🤖 Il est conçu pour être assumé temporairement par des entités, qu'il s'agisse d'un service AWS, d'une application, ou d'un utilisateur d'un autre compte AWS.

Le rôle est essentiel pour mettre en œuvre le principe du moindre privilège en permettant à une entité d'obtenir des autorisations pour une durée limitée, sans avoir à stocker de clés d'accès permanentes.

Comment Fonctionne un Rôle IAM

Un Rôle IAM se compose de deux éléments principaux :



Politique d'Autorisation (Permissions Policy)

Identique à une politique d'utilisateur, elle définit ce que l'entité peut faire une fois le rôle assumé (ex: `s3:PutObject`, `ec2:DescribeInstances`).



Politique d'Approximation (Trust Policy)

C'est ce qui rend le rôle unique. Elle définit qui est autorisé à assumer ce rôle. On y spécifie un Principal (l'entité de confiance) autorisé à "croire" en ce rôle (ex: l'ARN d'une instance EC2, l'ID d'un autre compte AWS, ou le service `ec2.amazonaws.com`).



Analogie

Imaginez un rôle IAM comme un uniforme de travail.

- L'uniforme (le Rôle) lui-même n'a pas d'identité, mais il est livré avec une liste de tâches autorisées (Politique d'Autorisation).
- Il y a une liste de personnes (Politique d'Approximation) autorisées à porter cet uniforme.

Lorsqu'une personne ou un service enfle l'uniforme, il obtient temporairement les autorisations qui y sont attachées.

Cas d'Utilisation Typiques

Les rôles IAM sont utilisés pour déléguer l'accès de manière sécurisée et limitée dans le temps :



Rôles pour les Services AWS (Service Roles)

C'est le cas d'utilisation le plus courant. Un service AWS (comme EC2, Lambda ou ECS) a besoin d'interagir avec d'autres services AWS.

- **Exemple :** Une instance EC2 a besoin de lire des fichiers d'un bucket S3.
- **Solution :** Au lieu de stocker des clés d'accès permanentes sur l'instance, on crée un rôle avec une politique s3:GetObject et on attache ce rôle à l'instance. La Politique d'Approximation autorise ec2.amazonaws.com à assumer ce rôle.



Rôles pour l'Accès Cross-Account (Cross-Account Access)

Un utilisateur ou un service d'un Compte A doit accéder aux ressources d'un Compte B.

- **Exemple :** Un administrateur du compte de Production (A) doit accéder aux données de journalisation stockées dans le compte de Développement (B).
- **Solution :** Dans le compte B, on crée un rôle. La Politique d'Approximation autorise l'ARN de l'utilisateur ou du compte A à assumer ce rôle.



Rôles pour l'Identité Web (Web Identity Federation)

Permettre à des utilisateurs de se connecter via des fournisseurs d'identité externes (comme Google, Facebook, ou un fournisseur SAML d'entreprise) et d'obtenir des autorisations AWS temporaires via un rôle.

Merci !

